

GeneralSurvey

Owner: guea0902-bour0703

Reviewer:

Contributors:

Date Generated: Fri Sep 18 2026

Executive Summary

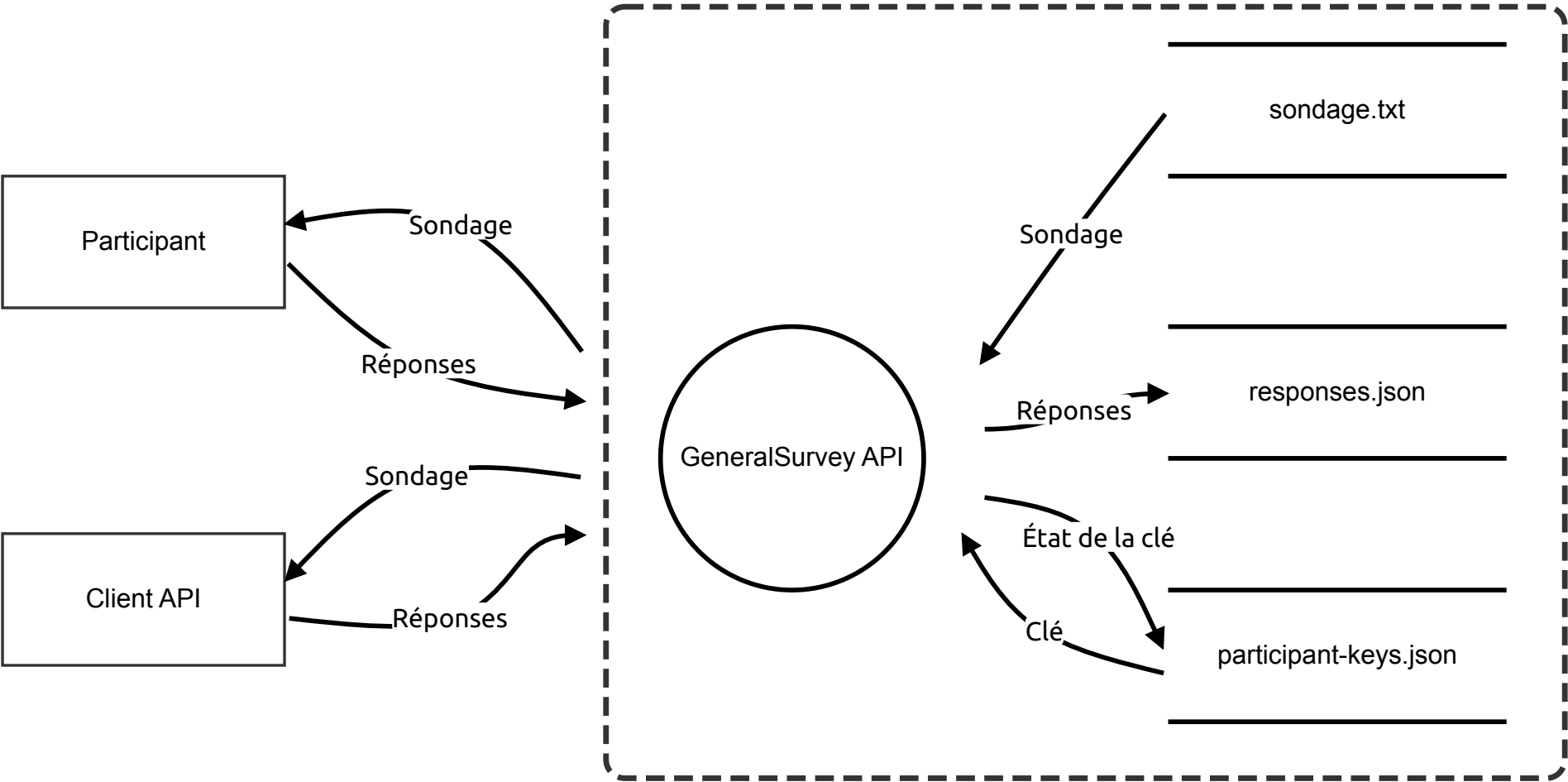
High level system description

Modèle STRIDE de l'API GeneralSurvey permettant la consultation de sondages et la soumission anonyme de réponses à l'aide de clés uniques.

Summary

Total Threats	25
Total Mitigated	13
Total Open	12
Open / Critical Severity	0
Open / High Severity	3
Open / Medium Severity	7
Open / Low Severity	2

GeneralSurvey - Modèle STRIDE



GeneralSurvey - Modèle STRIDE

Participant (Actor)

Description: Personne qui répond au sondage à l'aide d'une clé unique.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
	Usurpation d'une clé de participant	Spoofing	High	Mitigated		Une personne qui obtient une clé de participant valide pourrait l'utiliser pour soumettre une réponse à la place du participant auquel la clé était destinée.	Les clés sont générées de façon unique et sont vérifiées par l'API. Une clé est consommée après une réponse valide et ne peut plus être réutilisée.

Client API (Actor)

Description: Application autorisée à communiquer avec l'API GeneralSurvey.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
	Usurpation du client API	Spoofing	High	Mitigated		Un attaquant pourrait tenter d'utiliser l'API sans être une application autorisée.	Les requêtes vers l'API nécessitent une clé API transmise dans l'en-tête X-API-Key. Les requêtes sans clé ou avec une clé invalide sont refusées.

GeneralSurvey API (Process)

Description: API REST ASP.NET Core responsable de l'authentification, de la validation des réponses et de la gestion des sondages.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
	Contournement de l'authentification API	Spoofing	High	Mitigated		Un attaquant pourrait tenter d'accéder aux fonctionnalités de l'API sans fournir une clé API valide.	Le middleware ApiKeyMiddleware vérifie X-API-Key avant d'autoriser l'accès aux contrôleurs.
	Soumission de réponses invalides	Tampering	High	Mitigated		Un client malveillant pourrait modifier le contenu d'une réponse ou ajouter des réponses qui ne correspondent pas au sondage.	L'API vérifie que le sondage existe, que toutes les questions sont présentes, qu'elles sont uniques et que chaque réponse correspond à une option valide.
	Déni de service par requêtes répétées	Denial of service	Medium	Open		Un attaquant pourrait envoyer un grand nombre de requêtes afin de consommer les ressources de l'API ou du système de fichiers.	Ajouter éventuellement une limitation du nombre de requêtes par client et surveiller les accès anormaux.
	Élévation des privilèges	Elevation of privilege	Medium	Mitigated		Un participant pourrait tenter d'utiliser une fonctionnalité réservée à un client API autorisé.	L'API distingue l'authentification du client avec X-API-Key de l'authentification du participant avec X-Participant-Key.

sondage.txt (Store)

Description: Fichier contenant les sondages, les questions et les choix de réponses.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
	Modification du contenu du sondage	Tampering	Medium	Open		Une personne ayant accès au serveur pourrait modifier les questions ou les choix de réponses directement dans le fichier.	Restreindre les permissions du fichier au compte utilisé par l'application et envisager l'utilisation d'une signature ou d'un mécanisme d'intégrité.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
	Divulgateion du contenu du sondage	Information disclosure	Low	Open		Le contenu du fichier pourrait être consulté directement si les permissions du système de fichiers sont mal configurées.	Conserver le fichier uniquement dans le répertoire du serveur et limiter les permissions de lecture aux comptes nécessaires.

responses.json (Store)

Description: Fichier contenant les réponses aux sondages. La clé du participant n'est pas enregistrée avec la réponse.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
	Divulgateion des réponses	Information disclosure	High	Open		Une personne ayant accès au fichier pourrait consulter les réponses enregistrées.	Restreindre les permissions du fichier au serveur et au compte de l'application. En production, chiffrer les données sensibles au repos.
	Modification des réponses	Tampering	High	Open		Une personne ayant accès au fichier pourrait modifier ou supprimer des réponses déjà enregistrées.	Restreindre les permissions du fichier et envisager un mécanisme d'intégrité ou une base de données avec contrôle d'accès.
	Association d'une réponse avec un participant	Information disclosure	Medium	Mitigated		L'association directe entre une réponse et la clé du participant pourrait compromettre l'anonymat.	La clé du participant n'est pas enregistrée dans responses.json. Elle sert uniquement à autoriser et à consommer la participation.

participant-keys.json (Store)

Description: Banque de clés uniques permettant aux participants de répondre une seule fois.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
	Vol de clés de participants	Information disclosure	High	Mitigated		Un accès non autorisé au fichier pourrait permettre de récupérer des clés de participants encore valides.	Les clés de participants sont maintenant stockées sous forme de hash dans le fichier participant_keys.json. Ainsi, un accès non autorisé au fichier ne permet pas de récupérer directement les clés de participants valides.
	Réutilisation d'une clé	Spoofing	High	Mitigated		Un participant pourrait tenter d'utiliser plusieurs fois la même clé pour participer au sondage.	La clé est marquée comme utilisée après une réponse valide. Une clé déjà utilisée n'est plus considérée comme valide.
	Modification de l'état des clés	Tampering	Medium	Open		Une modification non autorisée du fichier pourrait remettre une clé utilisée à l'état inutilisé.	Restreindre les permissions du fichier et utiliser un stockage avec contrôle d'intégrité en production.

Consultation du sondage (Data Flow)

Description: Le participant consulte les questions du sondage.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
	Interception des réponses	Information disclosure	High	Mitigated		Les questions du sondage transitent sur un réseau public et pourraient être interceptées.	Utiliser HTTPS afin de chiffrer les communications entre le participant et l'API.

Soumission des réponses (Data Flow)

Description: Le participant envoie ses réponses à l'API avec une clé de participant unique.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
	Modification des réponses en transit	Tampering	High	Mitigated		Un attaquant situé sur le réseau pourrait tenter de modifier une réponse avant qu'elle atteigne l'API.	HTTPS fournit l'intégrité du canal de communication.
	Vol de la clé de participant	Spoofing	High	Open		Si la clé de participant est compromise avant son utilisation, une autre personne pourrait l'utiliser.	Utiliser HTTPS, éviter de journaliser les clés et limiter leur durée de validité lorsque cela est possible.

Consultation sondage (client) (Data Flow)

Description: Le client API reçoit les questions du sondage depuis l'API.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
	Interception de la clé API	Information disclosure	High	Mitigated		La clé API pourrait être interceptée lorsqu'elle est transmise au serveur.	Les requêtes API utilisent HTTPS afin de protéger la clé API en transit.

Accès API (Data Flow)

Description: Requête provenant d'une application autorisée et authentifiée par clé API.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
	Usurpation d'une requête API	Spoofing	High	Mitigated		Un attaquant pourrait tenter de fabriquer une requête API en utilisant une clé invalide ou absente.	Le middleware vérifie systématiquement X-API-Key et rejette les requêtes qui ne possèdent pas une clé valide.

Lecture des sondages (Data Flow)

Description: L'API lit les sondages, les questions et les choix de réponses depuis le fichier de données.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
	Modification du contenu du sondage	Tampering	Medium	Open		Un attaquant ayant accès au système de fichiers pourrait modifier sondage.txt avant sa lecture par l'API.	Limiter les permissions d'écriture sur sondage.txt au compte administrateur nécessaire. En production, utiliser un mécanisme permettant de vérifier l'intégrité du fichier.
	Divulgation du contenu du sondage	Information disclosure	Low	Open		Une personne ayant un accès non autorisé au système de fichiers pourrait lire directement le contenu de sondage.txt.	Restreindre les permissions de lecture du fichier au compte utilisé par l'application et aux administrateurs autorisés.
	Indisponibilité du fichier de sondage	Denial of service	Medium	Open		La suppression, la corruption ou l'indisponibilité de sondage.txt pourrait empêcher l'API de charger correctement les sondages.	Vérifier l'existence et l'intégrité du fichier au démarrage de l'application et prévoir une sauvegarde du fichier.

Enregistrement des réponses (Data Flow)

Description: L'API enregistre les réponses validées.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
	Corruption du fichier de réponses	Tampering	Medium	Open		Une interruption pendant l'écriture ou une modification concurrente pourrait corrompre responses.json.	Utiliser une écriture atomique ou une base de données dans une version de production.

Écriture état clés (Data Flow)

Description: L'API met à jour l'état des clés (used: true) après consommation.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
	Modification de l'état des clés	Tampering	Medium	Open		Une modification non autorisée du fichier pourrait remettre une clé utilisée à l'état inutilisé.	Restreindre les permissions du fichier et utiliser un stockage avec contrôle d'intégrité en production.

Lecture clés (Data Flow)

Description: L'API lit l'état des clés de participants depuis le fichier.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
	Condition de concurrence lors de la consommation (TOCTOU)	Tampering	Medium	Mitigated		Deux requêtes simultanées pourraient théoriquement tenter de valider et consommer la même clé avant que son état soit sauvegardé.	Mitigé par un ConcurrentDictionary<string, SemaphoreSlim> dans ParticipantKeyService. Un verrou par clé garantit qu'une seule requête à la fois peut valider et marquer la clé comme utilisée (used: true).